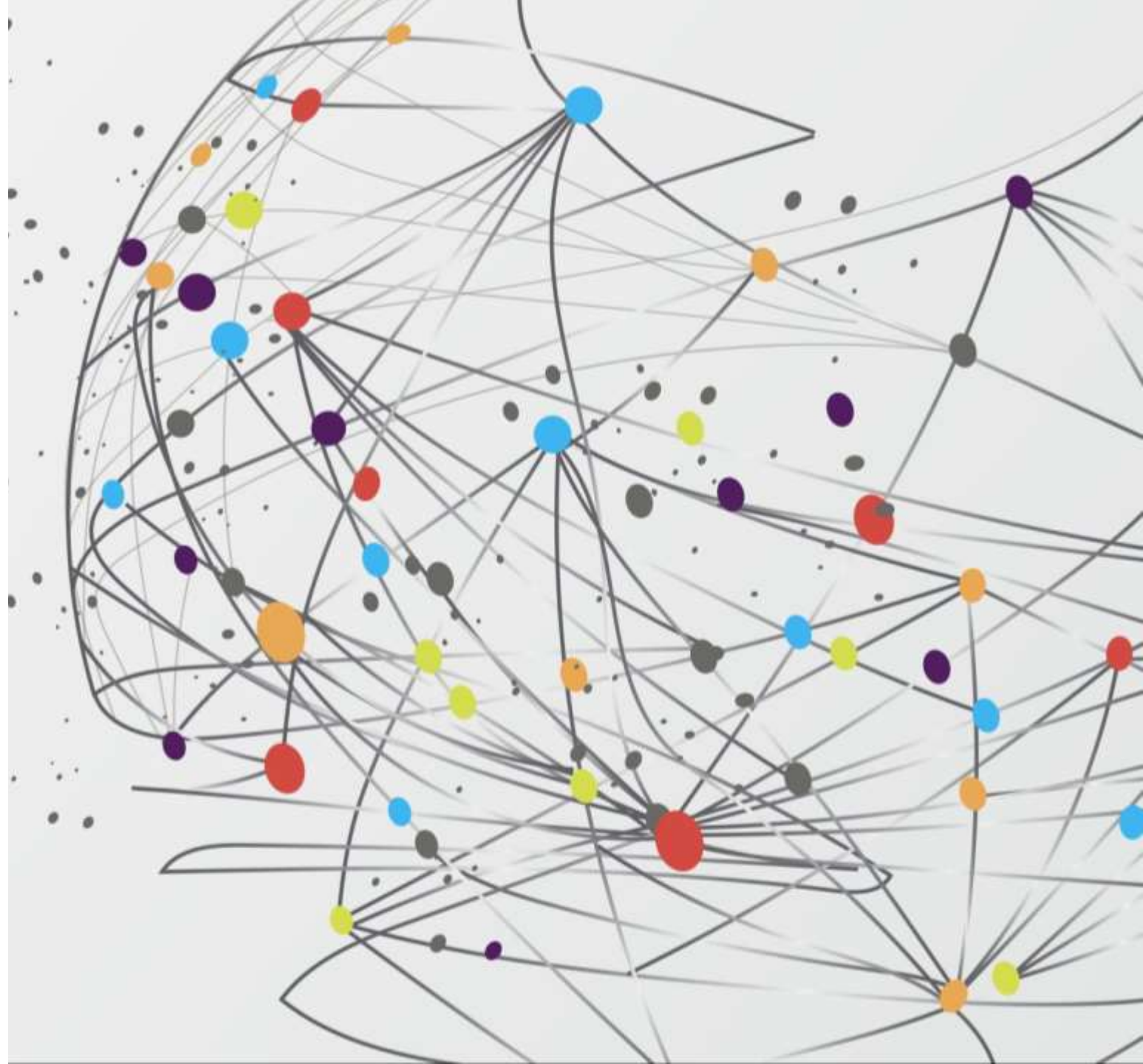

SİBER GÜVENLİĞE GİRİŞ

BÖLÜM 2 TEHDİT MODELLEME

Dr. Öğr. Üyesi Ahmet Kaşif

ahmet.kasif@btu.edu.tr



GENEL BAKIŞ

1. Risk Analizi
2. Güvenlik Özellikleri (CIA)
3. Kimlik Doğrulama – Yetkilendirme
4. Katmanlı Koruma
5. Sıfır Güven Modeli
6. Güvenlik Platformları (NIST)

2.1 RİSK

- $RISK = Zafiyet * Tehditler$
- Örnek: Laptopumuzun çalınması ihtimalini değerlendirelim.
 - Saldırgan: Hırsız
 - Zafiyet: Şifrelenmemiş verilerimiz
 - Sonuçlar: İtibar kaybı, kimlik hırsızlığı
- Bu sorunun önlenmesi amacıyla güvenlik kontrolleri almalıyız.
 - Belirle
 - Uygula
 - Ölç
 - Gözlemle

2.1.2 RİSK ANALİZİ

- Seç: Riskleri minimize eden güvenlik protokollerinin seçilmesi
 - Örnek: Laptop örneğinde, disk şifreleme yöntemi
- Uygula: Disk şifreleme yazılımının kurulması ve konfigüre edilmesi
- Ölç: Diskin gerçekten de şifrelenip şifrelenmediğinin kontrolü
- Gözlemle: Yöntemin etkinliğini sürdürebilmesi için sürekli takipte kalınması
 - Örnek: Yazılımın güvenlik güncellemelerinin yüklenmesi
- Çözümde bir zafiyet oluşursa, tekrar risk analizi yapılmalıdır.

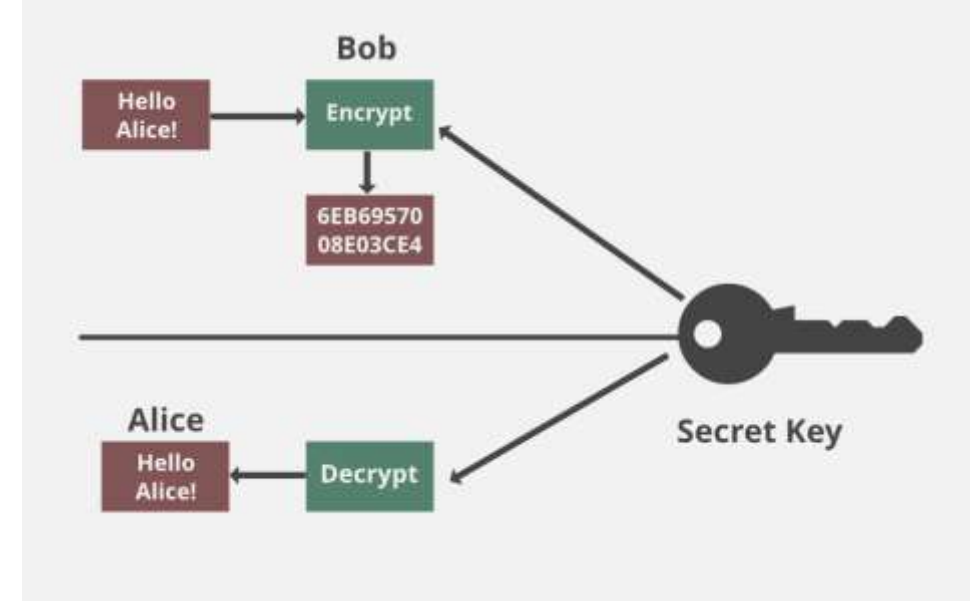
2.2.1 GÜVENLİK ÖZELLİKLERİ

- Bir kaynağın korunmasında güvenlik kontrollerinin uygulanmasında CIA kriterleri dikkate alınabilir.
 - Gizlilik (Confidentiality)
 - Bütünlük (Integrity)
 - Erişilebilirlik (Availability)



2.2.2 GİZLİLİK

- Bir kaynağı, hangi ölçüde paylaşım açmak istiyoruz?
- Gizlilik, korunması istenen kaynağın gizli kalmasını ifade eder.
- Örnek saldırı: Pasif dinleme (MITM)
- Çözümler: Yetkilendirme süreçleri, şifreleme



2.2.3 PASİF DİNLEME

CH 11][Elapsed: 1 min][2019-09-03 04:37

BSSID	PWR	Beacons	#Data, #/s	CH	MB	ENC	CIPHER	AUTH	ESSID
6A:17:	-32	9	11 0	6	130	WPA2	CCMP	PSK	HMS
D4:D7:	-62	11	10 0	1	130	WPA2	CCMP	MGT	
D4:D7:	-62	11	0 0	1	130	OPN			
D4:D7:	-62	12	0 0	1	130	OPN			
D4:D7:	-62	13	0 0	1	130	WPA2	CCMP	PSK	
D4:D7:	-62	10	0 0	1	54e.	WEP	WEP		
D4:D7:	-71	14	0 0	13	130	WPA2	CCMP	MGT	
D4:D7:	-72	9	0 0	13	130	WPA2	CCMP	PSK	
D4:D7:	-72	14	0 0	13	54e.	WEP	WEP		
D4:D7:	-72	11	0 0	13	130	OPN			
D4:D7:	-73	12	0 0	13	130	OPN			
D4:D7:	-76	5	0 0	5	130	WPA2	CCMP	PSK	
D4:D7:	-77	5	0 0	5	130	OPN			
D4:D7:	-78	3	0 0	5	54e.	WEP	WEP		
D4:D7:	-78	4	0 0	5	130	OPN			
D4:D7:	-78	3	1 0	5	130	WPA2	CCMP	MGT	
24:B6:	-80	3	0 0	9	130	WPA2	CCMP	MGT	
D4:D7:	-81	3	0 0	9	130	WPA2	CCMP	MGT	
24:B6:	-82	3	0 0	9	130	OPN			
24:B6:	-83	1	0 0	9	130	OPN			
EC:1A:	-80	5	1 0	1	130	WPA2	CCMP	PSK	
00:00:	-61	0	0 0	1	-1				
D4:D7:	-82	2	0 0	5	54e.	WEP	WEP		
D4:D7:	-81	3	0 0	9	130	OPN			
24:B6:	-79	2	0 0	9	54e.	WEP	WEP		

CH 6][Elapsed: 12 s][2019-09-03 05:57

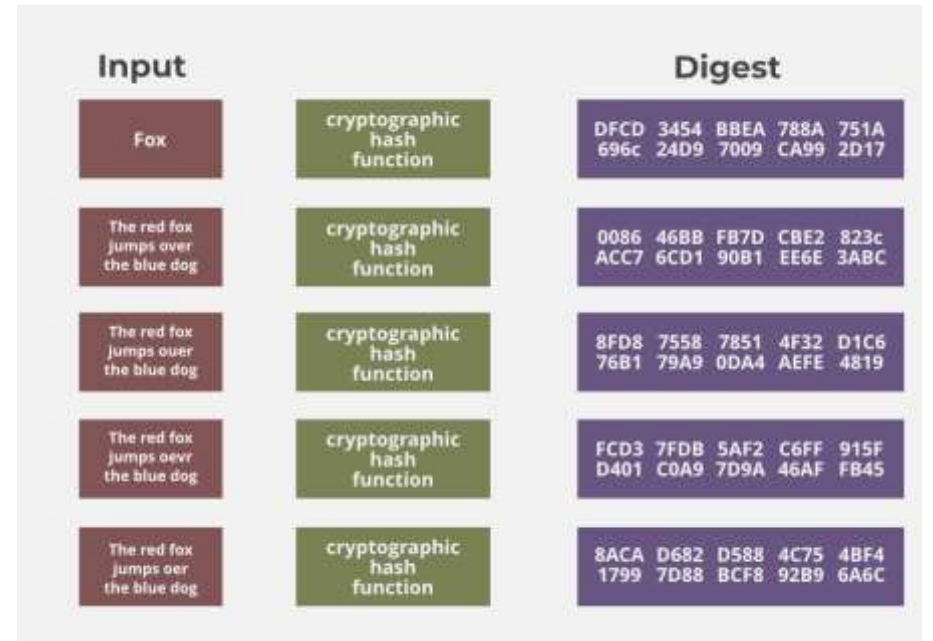
BSSID	PWR RXQ	Beacons	#Data, #/s	CH	MB	ENC	CIPHER	AUTH	ESSID
6A:17:	-26 88	139	216 72	6	130	WPA2	CCMP	PSK	HMS
BSSID	STATION	PWR	Rate	Lost	Frames	Probe			
6A:17:	A8:6D:	-28	0e- 0e	2320	197				
6A:17:	FC:77:	-48	0 - 6	0	4				

Pasif dinleme kullanarak ağ geçidi ile iletişim kuran cihazların tespiti

Kismet ile pasif dinleme ve çevredeki kablosuz yayınların tespiti

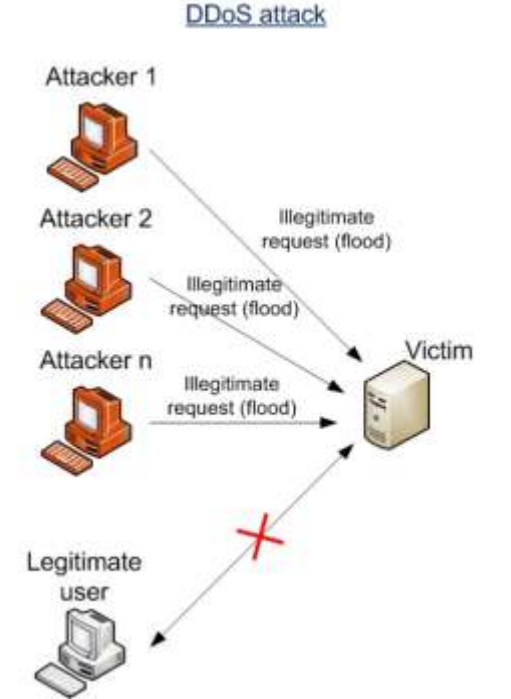
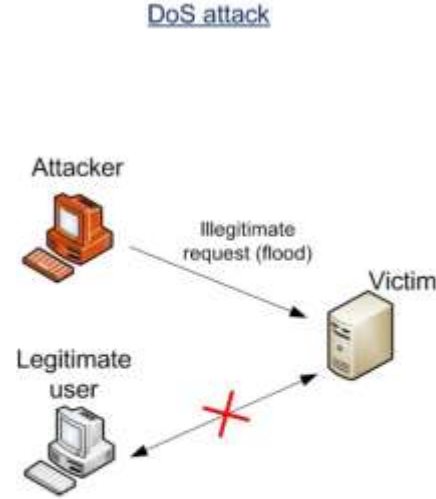
2.2.4 BÜTÜNLÜK

- Bütünlük: Verinin yaşam döngüsü boyunca orijinal formunu koruması gerektiğini ifade eder.
- Verinin hem saklandığı hem de taşındığı süreçlerde zafiyet meydana gelebilir.
- Çözüm: Hash alma
- Örnek Saldırı: Kurum web sayfasına sızılması, aradaki adam saldırısı



2.2.5 ERİŞİLEBİLİRLİK

- Erişilebilirlik: Veri yetkili tarafların kullanımını için sürekli bir şekilde hazır olmalıdır.
- Örnek saldırı: DoS, DDoS
- Çözümler: Donanımsal bakımların yapılması, yazılım çakışmalarının giderilmesi, OS güncellemelerinin gerçekleştirilmesi



2.3 KİMLİK DOĞRULAMA - YETKİLENDİRME

- Kimlik Doğrulama (Authentication): Kişinin beyan ettiği kişi olduğunu doğrular.
 - Şifreler, biyometrik veri veya doğrulama kodları
- Yetkilendirme (Authorization): Kişinin hangi kaynaklara erişebileceğini belirler.
 - Bir öğrenci kendi notlarını görebilirken, öğretmen herkesin notlarına erişebilmektedir.
- Üniversite kimlik kartını kullanarak;
 - Yerleşkeye girmek ?
 - Personel asansörü kullanmak?
 - Yüksek teknoloji araştırma laboratuvarına girmek?
- Önce kimlik doğrulama mı, yetkilendirme mi yapılır?

2.4 KATMANLI KORUMA

- Önle - Tespit Et – Düzelt
 - İdeal ortamda, önleyici tedbirler ile saldırıya maruz kalmadan süreçlerimizi yürütebiliriz.
 - Önleme etkisiz kalıp saldırıya uğradığımızda, tespit etmeliyiz.
 - Tespitte yetersiz kalırsak, sistemi eski haline döndürebilmeliyiz.
- Önleme

Bilinen Tehditler	Gizli Tehditler
Saldırı Tespit Sistemleri	Erişim Kontrol Listeleri (ACL)
Karalisteler	Sunucu tabanlı güvenlik duvarları
Çocuk koruma sistemleri	Güvenli silme
Dosya ve disk şifreleme	İzolasyon ve bölümlendirme

2.5 SIFIR GÜVEN MODELİ

- Seç: Riskleri minimize eden güvenlik protokollerinin seçilmesi
 - Örnek: Laptop örneğinde, disk şifreleme yöntemi
- Uygula: Disk şifreleme yazılımının kurulması ve konfigüre edilmesi
- Ölç: Diskin gerçekten de şifrelenip şifrelenmediğinin kontrolü
- Gözlemle: Yöntemin etkinliğini sürdürebilmesi için sürekli takipte kalınması
 - Örnek: Yazılımın güvenlik güncellemelerinin yüklenmesi
- Çözümde bir zafiyet oluşursa, tekrar risk analizi yapılmalıdır.

2.6 GÜVENLİK YÖNERGELERİ

- Sistemleri korumak için önerilen en iyi uygulamalar ve yönergeler kümesi
- Birey, şirket veya devlet seviyesinde standartları oluşturur.
- Neden ihtiyaç duyuyoruz?
 - Riskleri azaltır,
 - Uyumluluğu artırır,
 - Müşteri güvenini artırır,
 - Birçok iş ortağı birlikte çalışma ön şartı olarak sunabilir

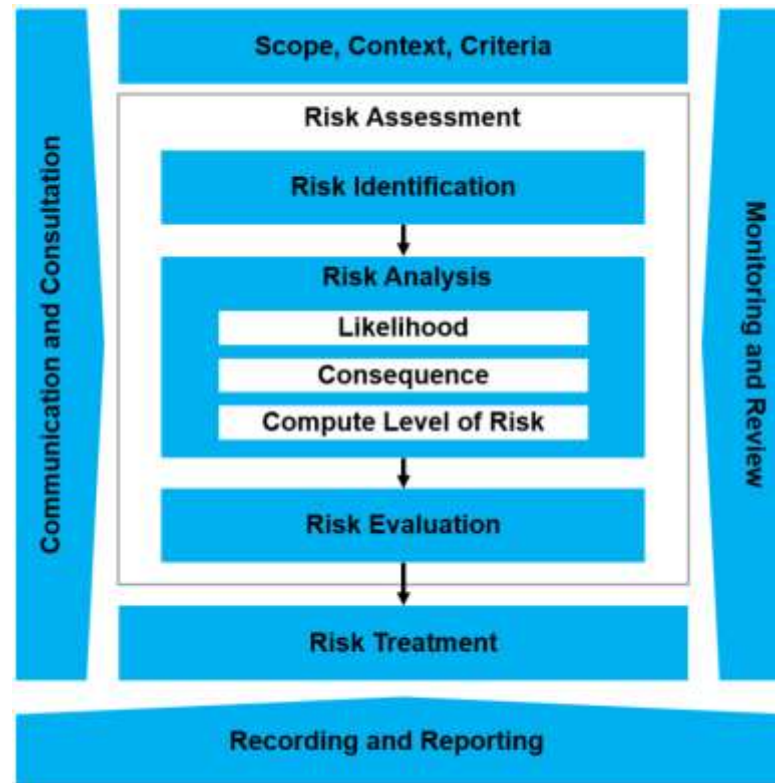
2.6.2 GÜVENLİK YÖNERGESİ ÖRNEKLERİ

- Uluslararası Standartlar Örgütü (ISO)
- ABD Ulusal Standart ve Teknoloji Enstitüsü (NIST)
- Bilgi ve İletişim Güvenliği Rehberi (BİGR)

2.6.3 ISO

- Bilgi Güvenliği ISO Standartları
 - ISO 27001: Bilgi Güvenliği Yönetim Sistemi
 - ISO 27002: Bilgi Güvenliği Kontrolleri

2.6.4 ISO 30001: RİSK YÖNETİM SÜRECİ



2.6.5 NIST SİBER GÜVENLİK ÇERÇEVESİ

- Tanımlama: Varlıklar, riskler ve tehditler belirlenir.
- Koruma: Veri ve sistemlerin güvenliğine yönelik çalışmalar gerçekleştirilir.
- Tespit Etme: Olağan dışı aktiviteler ve saldırılar algılanır.
- Tepki Verme: Güvenlik ihlallerine müdahale edilir.
- Kurtarma: Saldırı sonrası, sistemler eski haline getirilir.

2.6.6 BİDR

- Cumhurbaşkanlığı Dijital Dönüşüm Ofisi tarafından yayımlanmıştır.
- Kamu kurumları ve kritik altyapılar için zorunludur. Özel firmalar için öneri niteliğindedir.
- İçerik:
 - Risk Yönetimi ve Siber Tehdit İstihbaratı
 - Ağ ve Sistem Güvenliği
 - Kritik Veri Koruma ve Şifreleme
 - Bulut Bilişim ve Mobil Güvenlik Politikaları

2.6.7 GÜVENLİK YÖNERGELERİ KARŞILAŞTIRMASI

Özellik	NIST CSF	ISO 27001	BİGR (Türkiye)	KVKK (Türkiye)
Kaynak	ABD	Uluslararası	Türkiye	Türkiye
Kapsam	Siber güvenlik	Bilgi güvenliği yönetimi	Kamu kurumları ve kritik altyapılar	Kişisel veri güvenliği
Zorunluluk	Öneri niteliğinde	Sertifikasyon gerektirir	Kamu kurumları için zorunlu	Tüm şirketler için zorunlu
Hangi Durumda Kullanılır?	Risk yönetimi, saldırı tespiti	Bilgi güvenliği politikaları	Kamu kurumları ve siber tehditler	Veri koruma ve gizlilik yasaları
Örnek Kullanıcılar	Devlet kurumları, büyük şirketler	Kurumsal firmalar	Kamu & özel sektör	Veri işleyen tüm kuruluşlar

SORULAR?

Hatırlatma: yoklamaya katılım sağladığınızı kontrol edin,

Katılımınız için teşekkürler..